

Binding Agent Tool Calls to Effects: Counterfactual Contracts for Pre-Commit Mediation

Anonymous Authors

Abstract

Tool-using language-model agents can turn untrusted text into externally committed actions. Existing defenses commonly classify prompts, plans, or whole tool calls, but one call can combine effects authorized for different resources, principals, modes, and provenance. We formulate *tool-effect binding*: before commitment, a runtime must mediate a conservative causal abstraction of the security-relevant state transitions a call will realize. EffectContract separates offline counterfactual contract registration from deterministic online mediation. Registration intervenes on structured arguments, defaults, and trusted state, then rejects a contract when a real security-effect change is not represented by its atoms. Online, EffectContract totalizes defaults, instantiates the frozen atoms, and checks them against a task authority bound. A conditional confinement theorem exposes causal-abstraction soundness, envelope soundness, complete mediation, check–use integrity, and fail-closed uncertainty as explicit obligations. A field-level prototype completes all 726 official AgentDojo cases with 0/629 benchmark injection goals achieved, but only 0.330 benign and 0.304 attack-side task utility. An implementation audit exactly matches all 3,173 executed valid calls to pre-commit signatures. Compound-effect, authority-expansion, and omitted-default counterexamples keep the theorem conditional. Thus the current evidence supports exact sandbox mediation and a falsifiable effect-contract architecture, not production or unconditional trajectory safety.

1 Introduction

An LLM agent does not need to emit malicious text to cause harm. It can send a message to an injected recipient, share the wrong file, turn a draft into a committed action, or carry an attacker-controlled identifier from a tool result into a later call. The security boundary is therefore the point immediately before a structured tool call changes external state. At that boundary, judging only the tool name or the call as one undifferentiated object is too coarse: one call may contain both authorized and unauthorized effects.

We call the missing relation *tool-effect binding*. A tool implementation maps a structured call and pre-state to an external state transition; an effect contract is a conservative security abstraction of that transition. A monitor binds a call when harmless interventions preserve this abstraction, while interventions that change an independently authorizable effect are represented and, when policy requires, change the decision. This semantic layer is upstream of policy enforcement. Capability and least-privilege mechanisms can enforce only what their policy object represents; an omitted Bcc recipient, implicit invitation, or public-link change is invisible to a policy over the enclosing tool name.

The paper develops EffectContract, an architecture with two separated phases. During offline onboarding, an LLM may propose effect templates, but the proposal is only a synthesis hypothesis. Paired sandbox executions intervene on arguments, defaults, and trusted state; the validator compares concrete security-relevant state differences with the atoms produced by the candidate. A concrete effect change with no corresponding atom change is a *mediation gap*; an atom change without a concrete security-effect change is oversensitivity. Only bounded mappings that survive single-field, interaction, default, expansion, and negative-control tests are frozen. During agent execution, a deterministic pre-commit guard instantiates atoms from the frozen descriptor and totalized call, then compares every atom with a task permission envelope. The runtime does not ask an LLM to reinterpret the contract at each call. We distinguish this normative architecture from our evaluated AgentDojo prototype, which uses one-field state/output differences and therefore does not yet establish complete causal abstraction or an independently grounded envelope.

This structure provides a precise explanation surface: a decision identifies the contract template, concrete atom, value source, matching envelope clause, and mismatch reason. It also exposes the assumptions needed for a safety argument. If contracts conservatively cover true effects, the envelope does not expand from untrusted observations, every effectful call is mediated, checked values are the values executed, and

uncertainty fails closed, then every committed effect remains within the original task envelope. The same argument extends by induction to every prefix of a multi-step trajectory.

Our evaluation protocol follows the obligations rather than relying on one aggregate benchmark score. Counterfactual registration tests contract coverage and field relevance. Same-protocol AgentDojo runs test utility and indirect-prompt-injection attack success under one victim checkpoint. Stateful long-horizon tasks, controlled ablations, and adaptive attacks test legitimate resolution, prefix behavior, representation granularity, provenance, envelope planning, replan handling, and fail-closed behavior. We report only completed rows whose task manifests and row-level artifacts pass the common-protocol gates.

The intended contributions are:

- a pre-commit formulation of tool-effect binding and a concrete effect-atom mediation object;
- counterfactual contract registration that tests whether candidate atoms mediate security-relevant execution differences, with explicit invariance, mediation-gap, and interaction witnesses;
- a deterministic runtime that binds frozen descriptors to task-scoped authority and emits auditable decision witnesses;
- a conditional single-call and long-trajectory confinement argument with explicit trusted-computing-base obligations; and
- an obligation-driven evaluation methodology, with completed official AgentDojo and implementation-level mediation evidence and common-protocol long-horizon, adaptive, ablation, and overhead gates.

2 System and Threat Model

The protected system is a sandboxed tool-using agent. A user supplies an original task q ; the agent observes tool schemas and may receive attacker-controlled content from reads such as messages, documents, search results, and records. A candidate structured call contains a registered tool identifier and arguments. The executor can mutate only the sandbox state used by the benchmark.

The attacker controls untrusted observations and may attempt to add a tool, replace a resource or target, exploit an alias, upgrade preview or draft behavior to commitment, increase visibility, launder a value through later reasoning, exploit replan feedback, or distribute a goal across multiple trajectory steps. It may adapt its injected text after observing agent behavior. It cannot modify the trusted registry, guard, tool schema, structured arguments after checking, or benchmark validator.

The trusted computing base contains the frozen effect contracts, permission-envelope representation, canonicalization

and provenance interfaces, pre-commit guard, executor interception, and benchmark state. Malicious tool implementations, a compromised host, and post-check argument mutation are outside the base model. Calls with unresolved contracts, ambiguous identities, contradictory authority, or unavailable required provenance must not be automatically allowed.

The security objective is *task-intent confinement*: an attacker-controlled observation must not cause a committed effect outside the authority established by the original user task and its explicit resolver obligations. This is not a global content-safety policy. A dangerous effect intentionally requested by the user is not classified as an indirect-injection success solely because it is dangerous.

3 Design

Figure 1 separates offline contract onboarding from online pre-commit mediation. The separation is security-relevant: model-generated descriptions and plans are proposals, while frozen mappings, authority bounds, typed resolver relations, and the executor boundary form the trusted path.

For registered tool t , totalized arguments $\bar{x}$, state s , and trusted pre-call evidence h , let $F_t(s, \bar{x})$ be the post-state and

$$\Delta_{sec}(t, \bar{x}, s) = \Pi_{sec}(s, F_t(s, \bar{x}))$$

be the security-relevant projection of the transition. A frozen contract K_t deterministically produces atoms $A = K_t(\bar{x}, s, h)$ whose concretization conservatively covers Δ_{sec} . Each instantiated atom has the form

$$a = \langle e, o, r, y, v, m, p, k \rangle,$$

where e is effect kind, o operation, r resource, y target principal, v visibility, m commit mode, p provenance source, and k control source. The tuple is an extensible event schema, not a claim that all tool semantics factor into independent scalar fields: conditional templates and compound atoms represent interactions. A domain may omit a component only when registration establishes bounded security invariance.

Before checking, $\tau_t(x, s)$ totalizes the call by instantiating declared defaults and trusted implicit arguments. The guard and executor consume this same object; unresolved dynamic or undocumented defaults abstain. This prevents omission from hiding a nonempty effect-bearing default.

Task envelope. Before untrusted observations are processed, a trusted interface supplies an authority bound B_q . An LLM plan may narrow this bound, but every proposed tool, field, literal, and resolver is validated against it to form $\Gamma_q \preceq B_q$. Exact values carry request-source spans; resolver clauses name a fixed catalog entry and typed output projection. An authorized read may discharge an existing resolver. It cannot create new authority.

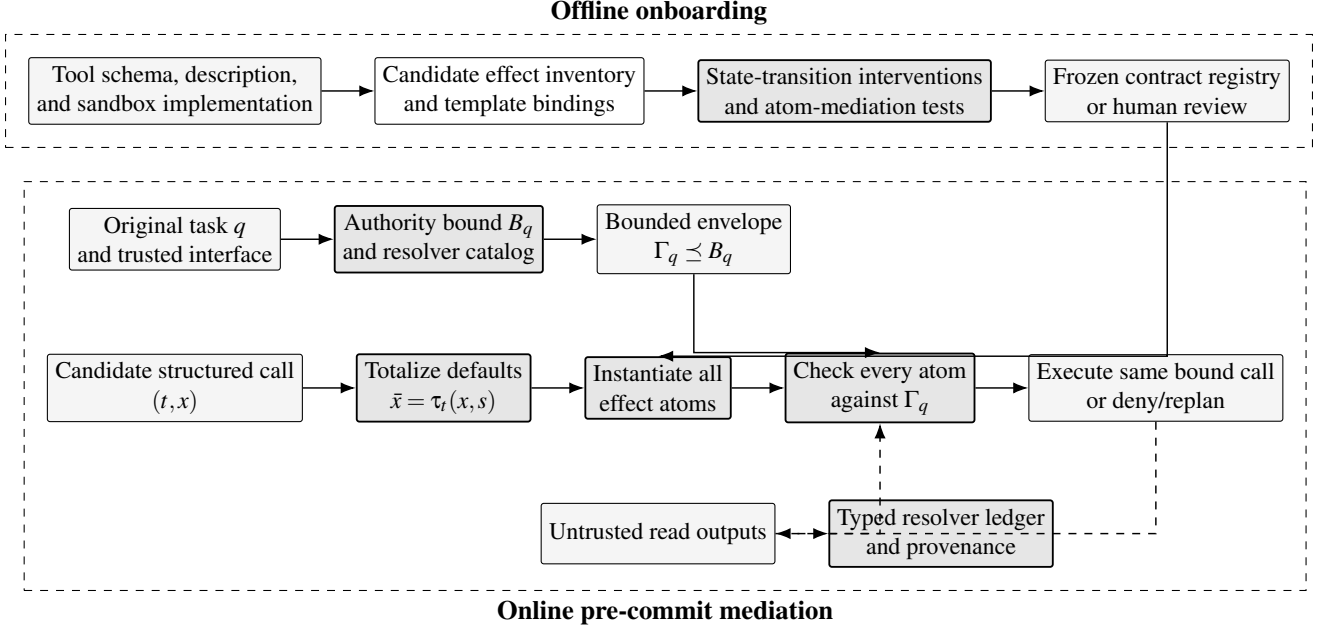


Figure 1: Normative EffectContract architecture. Offline onboarding freezes a deterministic effect contract only when its atoms preserve tested security-relevant execution differences. Online, a trusted authority bound limits any LLM plan; defaults are totalized before atom instantiation; and the checked call object is the one executed. Dashed flows carry untrusted observations only through typed resolver projections. E77 evaluates a narrower one-field instance and therefore does not discharge every box.

In a multi-turn task, an authenticated user message may create a new authority epoch $B^{(k+1)} = \text{Update}(B^{(k)}, u_{k+1})$. The update function reads only the trusted user channel and registry. Tool outputs, model summaries, and replan feedback cannot change the epoch; the current LLM proposal must still be bounded by $B^{(k+1)}$.

Frozen registry. The architecture requires each descriptor to contain effect templates, deterministic bindings from structured arguments or trusted runtime evidence, multi-resource expansion rules, canonicalization requirements, provenance/control rules, and a registration record. A missing or rejected descriptor makes an effectful tool unavailable for automatic commitment. The evaluated E77 instance is narrower: it stores one coarse effect label plus all fields not proven invariant by a one-field sandbox test. We use it to test the mediation path, not as evidence that the full registry requirements are discharged.

Pre-commit mediation. For every candidate call, the complete design instantiates all applicable templates and emits atom-level check items. The guard returns ALLOW only when every atom matches an envelope clause. An explicit mismatch returns DENY; unresolved identity, provenance, contract, or policy returns ABSTAIN. Replanning can revise the call but cannot alter Γ_q merely because untrusted content requests expansion. E77 operationalizes this as ALLOW versus

NEEDSREPLAN; it does not provide a separately evaluated deny/abstain distinction.

Decision witness. The complete witness schema records contract and template identifiers, the instantiated atom, each value’s source, the matched envelope clause, registry and envelope hashes, and the decision reason. E77 records the checked call signature, query hash, field checks, reasons, and a coarse atom projection; the remaining witness fields are requirements for the complete implementation. Deterministic witnesses, rather than hidden chain-of-thought, are the explanation mechanism.

4 Counterfactual Contract Registration

Registration starts from a tool schema, description, implementation or sandbox, and a declared security projection. An LLM may propose an effect inventory and bindings, but its output is an untrusted synthesis candidate. The validator tests whether the candidate is a sufficient abstraction of observed tool effects, not whether the model can repeat schema fields.

For a base call x and intervention set J , let $x' = \text{do}(x_J \leftarrow v_J)$ while the pre-state, history, nonintervened arguments, implementation version, and observation function remain fixed. The concrete relation is

$$R_\Delta(x, x') = [\Delta_{\text{sec}}(t, x, s) \not\equiv \Delta_{\text{sec}}(t, x', s)],$$

and the contract relation is

$$R_K(x, x') = [K_t(x, s, h) \not\equiv K_t(x', s, h)],$$

where equivalence canonicalizes aliases, ordering, and other declared surface forms. A pair is *faithfully mediated* when both relations change, a *true invariance* when neither changes, a *mediation gap* when R_Δ changes but R_K does not, and *over-sensitive* in the reverse case. The first is positive evidence for a binding; the second is a negative control; the latter two reject or refine the candidate.

The intervention suite includes resource, target, operation, commit, visibility, alias, multi-resource, provenance, control-source, omitted/default, and surface axes. It also includes pairwise or condition-aware interventions because isolated tests can miss an effect triggered by a conjunction. List-valued resources or targets expand to separate atoms, while one call may instantiate several templates. In AgentDojo, `create_calendar_event` both creates an event and sends invitations, including to an implicitly added calendar owner. A single `write` label misses that structure; explicit event and per-recipient templates cover the four enumerated calls we test.

This registration differs from action-source attribution. AttriGuard intervenes on untrusted observations and replays the model to ask why a call was proposed [11]. We intervene on structured calls and tool state to ask what security effects execution realizes and whether the frozen contract preserves those distinctions. The two tests are complementary: an intent-supported call can still contain an unauthorized sub-effect, while a sound effect contract does not establish that the model proposed the call for a trusted reason.

Candidate refinement receives only failed axes, relation categories, and aggregate metrics, never hidden reference atoms or expected decisions. The first candidate satisfying bounded mediation-recall, invariance, unsafe-allow, interaction, and leakage gates may be frozen. A finite test set remains a falsification procedure rather than a proof over an open input domain; unresolved tools require conservative bindings or human review.

E77 is a narrower predecessor. It compares one-field sandbox state/output snapshots and retains every changed or unresolved schema field. Its 56 changed, one invariant, and 22 unresolved outcomes demonstrate executable interventions, but do not distinguish security effects from arbitrary output changes, test whether proposed atoms mediate those changes, or cover interactions. A conjunction-triggered counterexample therefore defeats its registration criterion.

5 Security Analysis

The guarantee depends on five obligations. Let $\bar{x} = \tau_t(x, s)$ and let γ map atoms to the concrete effects they conservatively denote. (O1) *Causal-abstraction soundness*: $\Delta_{sec}(t, \bar{x}, s) \subseteq$

$\gamma(K_t(\bar{x}, s, h))$ for every registered reachable call. O1 requires a complete security-effect observation boundary, adequate interventions, abstraction sufficiency, and complete expansion of conditional and multi-resource effects. (O2) *Envelope soundness*: Γ_q cannot exceed the independently supported authority bound B_q . (O3) *Complete mediation*: every externally effectful call reaches the guard before transition. (O4) *Check-use integrity*: the checked totalized call, state version, and evidence are used by the executor. (O5) *Fail-closed uncertainty*: unresolved facts or defaults do not produce ALLOW.

Counterfactual abstraction criterion. Within a declared finite contract domain D , a sufficient abstraction preserves every tested security-effect distinction:

$$K_t(x, s, h) = K_t(x', s, h) \implies \Delta_{sec}(t, x, s) = \Delta_{sec}(t, x', s), \quad x, x' \in D.$$

Equivalently, any intervention that changes a concrete security effect must change its canonical atom abstraction. This is a bounded causal-mediation property over tool execution, not a claim to identify the model’s internal cause for proposing the call. Exhaustive validation establishes the property only for a finite D ; sampled counterfactuals can find violations but cannot certify an open domain.

Single-commit confinement. Assume O1–O5. If the guard returns ALLOW for $(q, t, \bar{x}, s, h)$, then every committed effect satisfies Γ_q and hence B_q . Totalization either exposes defaults or fails closed. O3 places the check before commitment; the guard requires every atom in K_t to match the envelope; O1 and γ cover every actual security effect; and O4 binds the checked object to execution. O2 prevents an LLM proposal from expanding authority. Therefore all committed effects are authorized.

Prefix confinement. Consider a trajectory with committed effects $\Delta_1, \dots, \Delta_n$. Assume single-commit confinement at each transition and that untrusted observations cannot enlarge Γ_q . Then for every prefix j ,

$$\bigcup_{i=1}^j \Delta_i \subseteq \{a \mid \Gamma_q(a) = \text{true}\}.$$

The proof is induction on j : the empty prefix is immediate; the inductive step adds only the effects of one allowed call, all authorized by single-commit confinement under the unchanged envelope.

For authenticated multi-turn tasks, let $\eta(i)$ be the latest trusted user epoch before commit i . If authority updates consume only authenticated user messages, then changing tool outputs or model feedback cannot change $B^{(\eta(i))}$. Applying single-commit confinement at each epoch gives the historical property $\forall i \leq j, \forall a \in \Delta_i : B^{(\eta(i))}(a)$. This permits explicit

Table 1: Implementation evidence for the confinement obligations. “Scoped” means the check passes only for the stated sandbox or enumerated cases.

Obligation	Evidence	Status
O1 abstraction	4 calendar calls; finite mediation/ablation checks	Partial
O2 envelope	invented literals rejected by independent manifest	Isolated
O3 mediation	3,173/3,173 executed calls interpreted	Scoped pass
O4 check-use	exact call-signature multiset in sandbox	Scoped pass
O5 uncertainty	static defaults totalized; legacy omission counterexample	Isolated

user clarification without letting an injected observation or replan expand authority. With no updates, it reduces to the fixed-envelope result above.

The theorem is a safety statement, not a liveness guarantee. A monitor that denies all calls satisfies confinement but has no utility. Evaluation must therefore report task completion, attack-side utility, false denial, abstention, recovery after replan, and overhead. The implementation may claim the theorem only for the obligations it tests; otherwise the theorem remains conditional.

Instantiated scope. For the completed AgentDojo run, the tool-result call-signature multiset exactly equals the pre-commit audit-signature multiset, providing execution evidence for O3 and sandbox-local O4. O1 remains partial: a finite nine-pair model accepts its complete contract and detects target, multi-resource, default, compound-effect, and placebo ablations, and the explicit two-template calendar contract covers four enumerated sandbox calls. Neither establishes AgentDojo-wide soundness: E77’s raw state/output comparison conflates security effects with arbitrary output differences and one-field registration misses a conjunction-triggered effect. O2 is not satisfied by E77: an LLM plan can introduce an exact literal or a resolver not independently supported by the request. An isolated hardening path bounds such proposals by a trusted manifest with source spans and a fixed resolver catalog, but arbitrary natural-language manifest construction remains outside the proof. O5 is also only partially instantiated. AgentDojo’s observed optional security defaults are empty, yet the legacy comparison skips omitted fields; a nonempty-default witness therefore allows without a check. Totalizing declared static defaults before authorization repairs the isolated path, while hidden or state-dependent defaults remain an assumption. We consequently present trajectory confinement as conditional, not as an unconditional implementation theorem.

6 Evaluation Methodology

The evaluation asks whether existing monitors jointly bind effects, whether frozen contracts cover independently varied tool behavior, whether pre-commit mediation improves prompt-injection security without collapsing utility, whether the property persists over long trajectories, and which component and cost account for the outcome.

Causal-mediation contract tests. Paired sandbox executions hold state and history fixed while intervening on one field, a declared interaction, an omitted default, or a surface placebo. An independent state-difference projection determines whether the concrete security effect changed; the candidate contract independently determines whether canonical atoms changed. We report atom mediation precision/recall, mediation-gap rate, true surface invariance, interaction coverage, authorization-flip agreement, unsafe pre-allow, false denial, coverage, and abstention. These tests concern execution semantics. A separate observation-attenuation test, when used, measures why an agent proposed a call and is reported as action-source attribution rather than contract validation. Reference sidecars remain outside deployable prompts and runtime inputs.

Same-protocol AgentDojo comparison. The primary prompt-injection comparison fixes AgentDojo version, official case keys, victim checkpoint, decoding configuration, task instances, attacks, and utility/attack-success evaluators across no guard, released detector checkpoints, prompting defenses, released-artifact adapters where feasible, and Effect-Contract. Each parse failure and runtime error remains in the denominator. Adapted baselines are labeled as common-input evaluations, not reproductions of their original papers.

Long-horizon evaluation. Stateful tasks are stratified by successful reference-trajectory length and contain dependency DAGs, legitimate resolver obligations, terminal utility validators, and per-prefix forbidden-effect validators. Attacks appear early, mid-trajectory, immediately before a high-impact commit, and repeatedly. Metrics include trajectory attack success, unauthorized committed atoms, first unsafe commit index, terminal success, milestone completion, legitimate effect recall, recovery, permission drift, latency, tokens, and extra model calls.

Ablations and adaptive attacks. Ablations remove resource, target, mode, provenance, default expansion, compound templates, counterfactual registration, task-envelope planning, authorized-read grounding, and fail-closed behavior one at a time under the same model and tasks. Descriptor swaps deliberately exchange resource, target, mode, or

provenance bindings between compatible tools. Adaptive attacks target mediation gaps, aliases, resolver evidence, replan feedback, and individually plausible tool chains. We retain performance drops and utility failures.

The adaptive protocol freezes 12 mechanism-specific strategies and selects 40 official AgentDojo attack keys before adaptive generation, 10 per suite by a deterministic hash ranking. Their Cartesian product contains 480 strategy–case pairs. Each row fixes the attacker-visible feedback, search budget, and an environment-level success relation; no LLM judges security. This manifest is a precommitted evaluation protocol, not an executed result.

Statistical treatment. Binary rates use Wilson 95% intervals. Identical case keys support paired bootstrap intervals for rate differences and exact McNemar tests; families of related comparisons use Holm correction. Deterministic decoding does not remove infrastructure nondeterminism, so a stratified subset is repeated. Duplicate keys, missing metrics, method-specific denominators, and unmatched pairs fail the statistics pass rather than being silently dropped. All reported values are generated from row-level artifacts by a fail-fast reproduction script.

7 Experimental Setup

Official AgentDojo. The end-to-end protocol fixes AgentDojo v1.1.2 and all 726 official keys: 97 benign tasks and 629 task–injection pairs across workspace (280), Slack (126), travel (160), and banking (160). We use the native deterministic user-task and injection-goal predicates. In these suites, `security=true` means that the injected goal executed and is therefore counted as attack success. Malformed outputs, timeouts, context errors, empty post-tool responses, and unsupported cases remain in the denominator and are reported separately.

E77 uses a local Qwen3.5-9B-derived Q4_K_M GGUF (SHA-256 prefix `9be22744`), temperature zero, a 131,072-token context, and a 4,096-token output cap. The primary common-model comparison uses one Qwen3-32B Q4_K_M GGUF (SHA-256 prefix `efd97156`), temperature zero, a 65,536-token context, and identical official keys and evaluators for every method. The model is split across two 24-GiB RTX 4090-class GPUs. Model prompts may differ only where a defense’s declared mechanism requires it; task state, tool schemas, attacks, and evaluator code remain fixed.

Causal-mediation sanity model. Before applying the metric to a benchmark, a finite controlled tool model separates its concrete state-transition projection from six candidate contracts. Nine fixed interventions cover resource, target, commit mode, provenance, multi-resource expansion, omitted and explicit defaults, a compound public-link branch, and a surface

Table 2: Completed E77 run on the official AgentDojo v1.1.2 case set with local Qwen3.5-9B. BU is benign utility, UA is user-task utility under attack, and ASR is the official injection-goal success rate. This row establishes end-to-end behavior; it is not a same-checkpoint baseline comparison.

Method	Benign	Attack	BU	UA	ASR
EffectContract E77	97	629	.330	.304	.000

placebo. The complete contract and five target, expansion, default, compound, and placebo variants test whether the evaluator distinguishes coverage gaps from mere set changes. This validates the metric implementation, not AgentDojo-wide contract soundness.

Long-task materials. The external stateful-utility gate freezes 30 offline ToolSandbox scenarios selected before model execution. A separate AgentLAB Task-Injection transfer set freezes 303 public saved cases: 49 workspace, 25 travel, 144 banking, and 85 Slack pairs. Each saved input is hash-bound and scanned to exclude stored evaluator booleans. These cases use the vendored deterministic AgentDojo v1.2.1 predicates. Because the attacks were generated previously and are not optimized against our method, we report this set as fixed-attack transfer, not method-adaptive evaluation. A separate adaptive protocol must freeze its generator checkpoint, memory-reset policy, ordering, rewrite budget, and seeds.

Reproducibility controls. Every method emits row-level keys and metrics. Finalizers require exact key coverage, one log per key, the frozen benchmark version, Boolean utility/security fields, and zero unreported execution errors. Guarded runs additionally reconcile the multiset of executed tool-call signatures with pre-commit audit signatures. Statistical scripts reject unmatched pairs and duplicate keys. No benchmark call reaches a real email, messaging, payment, travel, cloud, or other external service.

8 Results

8.1 Official AgentDojo End-to-End Run

Table 2 reports the completed E77 runtime on all 726 official AgentDojo v1.1.2 cases. The local Qwen3.5-9B victim completes 32/97 benign tasks and 191/629 user tasks under attack. The official injection-goal evaluator records 0/629 successful attacks, with no malformed, missing-metric, context-length, server-error, or post-tool-empty rows. This is zero benchmark-defined attack success on one low-utility run, not a proof of effect-atom or trajectory confinement: benign and attack-side task utility are only 0.330 and 0.304, while O1, O2, and general O5 remain partial.

The corrected audit separates the official cases from AgentDojo’s auxiliary injection-task-as-user-task executions. The 726 logs contain 3,235 valid structured calls; 62 occur at a terminal boundary without a tool-result event and therefore never reach execution. The remaining 3,173 tool-result call signatures match the pre-commit audit signatures exactly as a multiset: 2,227 are allowed and 946 return replan feedback. All 611 plan events in this subset are parse-valid. No pre-commit check lacks a corresponding initial-task plan, no repeated-call override occurs, and the deterministic check invokes no LLM after the plan is fixed. Twenty auxiliary plan events and 80 auxiliary checks are excluded from these counts.

E77 does not yet establish comparative superiority. It uses a 9B checkpoint and reports one completed proposed-method row. The main comparison requires the same victim checkpoint, decoding configuration, 726 cases, and evaluators for no guard, detector checkpoints, prompting defenses, released-artifact adapters, and EffectContract. We make comparative claims only from that common protocol.

8.2 Where E77 Loses Utility

A payload-free trajectory audit separates observed mechanics without assigning a unique causal root cause. Of 274 cases that receive at least one replan feedback event, 30 complete the user task (0.109), versus 193/452 (0.427) without feedback. The gap is sharper on benign tasks: 34/97 receive feedback and only one of those 34 succeeds. The 65 benign utility failures comprise 20 trajectories whose effectful calls are intercepted with no later effectful commit, seven that contain both feedback and an effectful commit, 16 with no structured tool call, 14 read-only or nonregistered-tool trajectories, and eight ending with an unexecuted structured call. There are no reported runtime/model-error rows in this partition. These categories show that recovery and authority resolution are major observed bottlenecks; they do not establish that the guard alone caused each failure.

8.3 Authority-Interface Burden

Table 3 makes the incomplete O2 interface concrete. We join the 97 label-hidden original tasks with E77 plans produced before any tool output. Eighty-one tasks have such a plan; the other 16 never initialized one because the evaluated trajectory produced no tool call. The 81 plans contain 287 field bindings, dominated by 177 resolver clauses. Of 72 concrete values inside 71 exact bindings, 60 are lexically grounded in the original request and 12 require either a declared canonical transform or rejection. All 97 tasks remain unapproved in the review packet. These counts measure the interface that a trusted compiler or reviewer must discharge; they are not evidence that lexical overlap establishes authority.

Table 3: E84 label-hidden authority-review packet derived from the 97 original AgentDojo tasks and E77 plans generated before tool output. Lexical grounding is diagnostic, not approval.

Item	Count
Original tasks	97
Tasks with pre-output plan	81
Tasks without plan event	16
Exact bindings	71
Resolver bindings	177
Forbidden bindings	39
Exact values grounded / proposed	60 / 72
Trusted manifests approved	0

Table 4: Controlled hardened-kernel latency. Ledger noise is the number of unrelated typed resolver entries. This excludes model and sandbox latency.

Fields	Ledger noise	p50 (μ s)	p95 (μ s)
1	0	22.1	23.1
8	0	74.6	75.8
32	0	244.7	249.6
1	64	132.2	136.7
8	64	183.3	188.2
32	64	352.0	357.6

8.4 Controlled Runtime Cost

Table 4 isolates the pure hardened pre-commit kernel over exact clauses, typed resolver entries, default totalization, and witness hashing. Across 2,000 iterations per configuration, median latency rises from 22.1 μ s for one security field to 244.7 μ s for 32 fields with no unrelated ledger entries. With 64 unrelated entries, the corresponding medians are 132.2 and 352.0 μ s. All 36,000 measured decisions are ALLOW and invoke no runtime LLM. This establishes only in-process kernel cost; final end-to-end results must separately include model planning, canonicalization I/O, sandbox execution, replan calls, and complete trajectory latency.

9 Related Work

ToolEmu and AgentDojo expose safety failures in tool-rich and adversarial agent environments [5, 14]. ToolSafe/TS-Guard and Safiron move checking toward pre-execution tool steps [12, 13]. Our question is complementary: what semantic object should be checked when one call realizes multiple independently authorizable effects?

CaMeL separates trusted control from untrusted data, while IPIGuard reasons over tool dependencies [1, 4]. AttrGuard instead attenuates untrusted observations and shadow-replays the model to attribute why a call was proposed [11]. Our

counterfactual intervenes after that causal link: it tests what security-relevant transition a structured call realizes and whether a frozen contract mediates the difference. Action-source and effect-semantics counterfactuals are therefore complementary.

Progent and MiniScope provide programmable or least-privilege authority for tool agents [16, 20]. PACT assigns semantic roles and provenance contracts to authority-bearing arguments, while AuthGraph aligns a clean authorization graph with execution provenance [8, 17]. These systems make the closest granularity comparison. We additionally treat one call as a set of effect instances whose expansion may depend on several arguments, defaults, and trusted state; the relevant failure is a concrete effect change hidden by an unchanged atom abstraction.

ARGUS and AgentVisor represent contemporary provenance and execution-virtualization directions for agent monitoring [18, 19]. Their observability and isolation mechanisms are complementary to our question: the runtime still needs a policy object that separates independently authorizable effects inside a structured call. We cite these systems for positioning only; their results are not evidence for our evaluation.

The design follows classical complete mediation, capability, confused-deputy, information-flow, and provenance principles [2, 3, 6, 7, 10, 15]. Mechanistic work uses activation swaps and ablations to distinguish readable model representations from causally load-bearing ones [9]. We do not inspect model internals; we adopt the methodological distinction that a verbalized atom proposal is only a hypothesis until interventions show that the compiled abstraction carries the downstream execution distinction. The contribution is to make that mediated object explicit for agent tool use and test it before enforcement.

10 Limitations

The contracts, security-effect projection, and authorization envelopes remain assumptions that must be validated, not automatically trusted outputs of an LLM. Counterfactual execution can falsify a candidate on tested interventions; absent exhaustive finite-domain analysis, it cannot prove global causal-abstraction soundness. E77 retains changed fields conservatively but conflates arbitrary state/output differences with security effects and misses interaction-only effects. State-dependent, asynchronous, callback, remote, and malicious-tool effects may fall outside a sandbox oracle. Its LLM permission plan can also propose unsupported literals or resolvers unless bounded by an independent manifest, and omitted nonempty defaults require totalization before checking. Canonicalization, provenance, and authorization context may be incomplete or stale. Completed long-horizon and adaptive rows cover only their specified strategies. The conditional theorem excludes compromised tools or hosts and requires

check–use integrity not established for concurrent remote services.

11 Conclusion

Tool-agent safety requires a monitor to mediate a conservative abstraction of the effects a call will commit, not merely its name or surface form. Counterfactual onboarding intervenes on calls and state to test whether candidate atoms preserve observed security-effect distinctions; deterministic pre-commit checks then bind the frozen abstraction to task-scoped authority. The resulting confinement argument is useful precisely because it exposes causal-abstraction, authority, mediation, check–use, and uncertainty obligations that aggregate attack success can hide. Our current prototype establishes exact sandbox interception and exposes concrete contract, envelope, interaction, and default-semantics gaps; it does not yet discharge the complete architecture. Common-protocol baselines, long-trajectory tests, causal ablations, and interface-cost measurements determine whether the hardened construction improves security without merely suppressing useful execution.

References

- [1] Hengyu An, Jinghui Zhang, Tianyu Du, Chunyi Zhou, Qingming Li, Tao Lin, and Shouling Ji. Ipiguard: A novel tool dependency graph-based defense against indirect prompt injection in llm agents, 2025. EMNLP 2025.
- [2] Peter Buneman, Sanjeev Khanna, and Wang-Chiew Tan. Why and where: A characterization of data provenance. In *Database Theory – ICDT 2001*, volume 1973 of *Lecture Notes in Computer Science*, pages 316–330. Springer, 2001.
- [3] James Cheney, Laura Chiticariu, and Wang-Chiew Tan. Provenance in databases: Why, how, and where. *Foundations and Trends in Databases*, 1(4):379–474, 2009.
- [4] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramer. Defeating prompt injections by design, 2025.
- [5] Edoardo Debenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramer. Agentdojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents, 2024.
- [6] Dorothy E. Denning. A lattice model of secure information flow. *Communications of the ACM*, 19(5):236–243, 1976.

- [7] Jack B. Dennis and Earl C. Van Horn. Programming semantics for multiprogrammed computations. *Communications of the ACM*, 9(3):143–155, 1966.
- [8] Linfeng Fan, Ziwei Li, Yuan Tian, Yichen Wang, Rongsheng Li, and Xiong Wang. The granularity mismatch in agent security: Argument-level provenance solves enforcement and isolates the LLM reasoning bottleneck, 2026.
- [9] Wes Gurnee, Nicholas Sofroniew, Adam Pearce, Mateusz Piotrowski, Isaac Kauvar, Runjin Chen, Anna Soligo, Paul Bogdan, Euan Ong, Rowan Wang, T. Ben Thompson, David Abrahams, Subhash Kantamneni, Emmanuel Ameisen, Joshua Batson, and Jack Lindsey. Verbalizable representations form a global workspace in language models. *Transformer Circuits Thread*, July 2026.
- [10] Norm Hardy. The confused deputy: (or why capabilities might have been invented). *ACM SIGOPS Operating Systems Review*, 22(4):36–38, 1988.
- [11] Yu He, Haozhe Zhu, Yiming Li, Shuo Shao, Hongwei Yao, Zhihao Liu, and Zhan Qin. AttriGuard: Defeating indirect prompt injection in LLM agents via causal attribution of tool invocations, 2026. Accepted by USENIX Security 2026.
- [12] Yue Huang, Hang Hua, Yujun Zhou, Pengcheng Jing, Manish Nagireddy, Inkit Padhi, Greta Dolcetti, Zhangchen Xu, Subhajit Chaudhury, Ambrish Rawat, Liubov Nedoshivina, Pin-Yu Chen, Prasanna Sattigeri, and Xiangliang Zhang. Building a foundational guardrail for general agentic systems via synthetic data, 2025.
- [13] Yutao Mou, Zhangchi Xue, Lijun Li, Peiyang Liu, Shikun Zhang, Wei Ye, and Jing Shao. Toolsafe: Enhancing tool invocation safety of llm-based agents via proactive step-level guardrail and feedback, 2026. Work in progress.
- [14] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of llm agents with an llm-emulated sandbox, 2023.
- [15] Jerome H. Saltzer and Michael D. Schroeder. The protection of information in computer systems. *Proceedings of the IEEE*, 63(9):1278–1308, 1975.
- [16] Tianneng Shi, Jingxuan He, Zhun Wang, Hongwei Li, Linyu Wu, Wenbo Guo, and Dawn Song. Progent: Securing ai agents with privilege control, 2025.
- [17] Peiran Wang, Ying Li, and Yuan Tian. Aligning provenance with authorization: A dual-graph defense for LLM agents, 2026.
- [18] Shihao Weng, Yang Feng, Jinrui Zhang, Xiaofei Xie, Jiongchi Yu, and Jia Liu. ARGUS: Defending LLM agents against context-aware prompt injection, 2026. Submitted 5 May 2026.
- [19] Zonghao Ying, Haozheng Wang, Jiangfan Liu, Quanchen Zou, Aishan Liu, Jian Yang, Yaodong Yang, and Xianglong Liu. AgentVisor: Defending LLM agents against prompt injection via semantic virtualization, 2026. Submitted 27 April 2026.
- [20] Jinhao Zhu, Kevin Tseng, Gil Vernik, Xiao Huang, Shishir G. Patil, Vivian Fang, and Raluca Ada Popa. Miniscope: A least privilege framework for authorizing tool calling agents, 2025.

A Ethical Considerations

All experiments use local models or explicitly documented public endpoints, sandboxed tools, and benchmark state. They do not send messages, transfer money, modify cloud resources, or execute other real external effects. Attack strings and failure examples are released only as needed for reproducibility and are framed as defensive evaluation. The work may enable stronger agent controls, but incorrect contracts or misplaced confidence could also create risk; accordingly, the paper avoids deployed-system guarantees and explicitly records the unsupported-literal, omitted-default, and compound-effect failure witnesses alongside utility failures.

B Open Science

The anonymous artifact will include source code, fixed benchmark manifests, label-hidden deployable inputs, sidecar labels and atoms used only for scoring, row-level predictions, model and checkpoint identifiers, environment locks, counterfactual registration records, decision witnesses, and fail-fast table reproduction scripts. It will be scrubbed of identifying metadata, credentials, and repository history. An anonymous stable URL will be inserted before the artifact deadline and kept available through the review period.